Firewall and IDS/IPS Evasion

`Nmap` gives us many different ways to bypass firewalls rules and IDS/IPS. These methods include the fragmentation of packets, the use of decoys, and others that we will discuss in this section.

Firewalls

A firewall is a security measure against unauthorized connection attempts from external networks. Every firewall security system is based on a software component that monitors network traffic between the firewall and incoming data connections and decides how to handle the connection based on the rules that have been set, It checks whether individual network packets are being passed, ignored, or blocked. This mechanism is designed to prevent unwanted connections that could be potentially dangerous.

IDS/IPS

Like the firewall, the intrusion detection system (`IDS`) and intrusion prevention system (`IPS`) are also software-based components. `IDS` scans the network for potential attacks, analyzes them, and reports any detected attacks. `IPS` complements `IDS` by taking specific defensive measures if a potential attack should have been detected. The analysis of such attacks is based on pattern matching and signatures. If specific patterns are detected, such as a service detection scan, `IPS` may prevent the pending connection attempts.

Determine Firewalls and Their Rules

We already know that when a port is shown as filtered, it can have several reasons. In most cases, firewalls have certain rules set to handle specific connections. The packets can either be dropped, or rejected. The dropped packets are ignored, and no response is returned from the host.

This is different for rejected packets, which elicit an explicit response. TCP packets are returned with an RST flag, while ICMP can contain different types of error codes.

Such errors include:

- Net Unreachable

- Net Prohibited
- Host Unreachable
- Host Prohibited
- Port Unreachable
- Proto Unreachable

Nmap's TCP ACK scan (`-sA`) method is much harder to filter for firewalls and IDS/IPS systems than regular SYN (`-sS`) or Connect scans (`sT`) because they only send a TCP packet with only the `ACK` flag. When a port is closed or open, the host must respond with an `RST` flag. Unlike outgoing connections, all connection attempts (with the `SYN` flag) from external networks are usually blocked by firewalls. However, the packets with the `ACK` flag are often passed by the firewall because the firewall cannot determine whether the connection was first established from the external network or the internal network.

SYN-Scan

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -p 21,22,25 -sS -Pn
-n --disable-arp-ping
--packet-trace

Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-21 14:56
CEST
SENT (0.0278s) TCP 10.10.14.2:57347 > 10.129.2.28:22 S ttl=
53 id=22412 iplen=44
seq=4092255222 win=1024 <mss 1460>
SENT (0.0278s) TCP 10.10.14.2:57347 > 10.129.2.28:25 S ttl=
50 id=62291 iplen=44
seq=4092255222 win=1024 <mss 1460>
SENT (0.0278s) TCP 10.10.14.2:57347 > 10.129.2.28:21 S ttl=
58 id=38696 iplen=44
seq=4092255222 win=1024 <mss 1460>
RCVD (0.0329s) ICMP [10.129.2.28 > 10.10.14.2 Port 21 unrea
chable (type=3/code=3) ]
IP [ttl=64 id=40884 iplen=72 ]
RCVD (0.0341s) TCP 10.129.2.28:22 > 10.10.14.2:57347 SA ttl
=64 id=0 iplen=44
```

```
seq=1153454414 win=64240 <mss 1460>
RCVD (1.0386s) TCP 10.129.2.28:22 > 10.10.14.2:57347 SA ttl
=64 id=0 iplen=44
seq=1153454414 win=64240 <mss 1460>
SENT (1.1366s) TCP 10.10.14.2:57348 > 10.129.2.28:25 S ttl=
44 id=6796 iplen=44
seq=4092320759 win=1024 <mss 1460>
Nmap scan report for 10.129.2.28
Host is up (0.0053s latency).

PORT   STATE    SERVICE
21/tcp filtered ftp
22/tcp open     ssh
25/tcp filtered smtp
MAC Address: DE:AD:00:00:BE:EF (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 0.07 seconds
```

ACK-Scan

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -p 21,22,25 -sA -Pn
-n --disable-arp-ping
--packet-trace

Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-21 14:57
CEST
SENT (0.0422s) TCP 10.10.14.2:49343 > 10.129.2.28:21 A ttl=
49 id=12381 iplen=40
seq=0 win=1024
SENT (0.0423s) TCP 10.10.14.2:49343 > 10.129.2.28:22 A ttl=
41 id=5146 iplen=40
seq=0 win=1024
SENT (0.0423s) TCP 10.10.14.2:49343 > 10.129.2.28:25 A ttl=
49 id=5800 iplen=40
seq=0 win=1024
RCVD (0.1252s) ICMP [10.129.2.28 > 10.10.14.2 Port 21 unrea
chable (type=3/code=3) ]
```

```
IP [ttl=64 id=55628 iplen=68 ]
RCVD (0.1268s) TCP 10.129.2.28:22 > 10.10.14.2:49343 R ttl=
64 id=0 iplen=40
seq=1660784500 win=0
SENT (1.3837s) TCP 10.10.14.2:49344 > 10.129.2.28:25 A ttl=
59 id=21915 iplen=40
seq=0 win=1024
Nmap scan report for 10.129.2.28
Host is up (0.083s latency).

PORT   STATE      SERVICE
21/tcp filtered   ftp
22/tcp unfiltered ssh
25/tcp filtered   smtp
MAC Address: DE:AD:00:00:BE:EF (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds
```

Scanning Options	Description
`10.129.2.28`	Scans the specified target.
`-p 21,22,25`	Scans only the specified ports.
`-sS`	Performs SYN scan on specified ports.
`-sA`	Performs ACK scan on specified ports.
`-Pn`	Disables ICMP Echo requests.
`-n`	Disables DNS resolution.
`--disable-arp-ping`	Disables ARP ping.
`--packet-trace`	Shows all packets sent and received.

Please pay attention to the RCVD packets and its set flag we receive from our target. With the SYN scan (`-sS`) our target tries to establish the TCP connection by sending a packet back with the SYN-ACK (`SA`) flags set and with the ACK scan (`-sA`) we get the `RST` flag because TCP port 22 is open. For the TCP port 25, we do not receive any packets back, which indicates that the packets will be dropped.

Detect IDS/IPS

Unlike firewalls and their rules, the detection of IDS/IPS systems is much more difficult because these are passive traffic monitoring systems. `IDS systems` examine all connections between hosts. If the IDS finds packets containing the defined contents or specifications, the administrator is notified and takes appropriate action in the worst case.

`IPS systems` take measures configured by the administrator independently to prevent potential attacks automatically. It is essential to know that IDS and IPS are different applications and that IPS serves as a complement to IDS.

Several virtual private servers (`VPS`) with different IP addresses are recommended to determine whether such systems are on the target network during a penetration test. If the administrator detects such a potential attack on the target network, the first step is to block the IP address from which the potential attack comes.As a result, we will no longer be able to access the network using that IP address, and our Internet Service Provider (`ISP`) will be contacted and blocked from all access to the Internet.

• `IDS systems` alone are usually there to help administrators detect potential attacks on their network. They can then decide how to handle such connections. We can trigger certain security measures from an administrator, for example, by aggressively scanning a single port and its service. Based on whether specific security measures are taken, we can detect if the network has some monitoring applications or not.

• One method to determine whether such `IPS system` is present in the target network is to scan from a single host (`VPS`). If at any time this host is blocked and has no access to the target network, we know that the administrator has taken some security measures. Accordingly, we can continue our penetration test with another `VPS`.

Decoys

There are cases in which administrators block specific subnets from different regions in principle. This prevents any access to the target network. Another example is when IPS should block us. For this reason, the Decoy scanning method (`-D`) is the right choice. With this method, Nmap generates various random IP addresses inserted into the IP header to disguise the origin of the packet sent. With this method, we can generate random (`RND`) a specific

number (for example: `5`) of IP addresses separated by a colon (`:`). Our real IP address is then randomly placed between the generated IP addresses. In the next example, our real IP address is therefore placed in the second position. Another critical point is that the decoys must be alive. Otherwise, the service on the target may be unreachable due to SYN-flooding security mechanisms.

Scan by Using Decoys

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -p 80 -sS -Pn -n --d
isable-arp-ping
--packet-trace -D RND:5

Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-21 16:14
CEST
SENT (0.0378s) TCP 102.52.161.59:59289 > 10.129.2.28:80 S t
tl=42 id=29822 iplen=44
seq=3687542010 win=1024 <mss 1460>
SENT (0.0378s) TCP 10.10.14.2:59289 > 10.129.2.28:80 S ttl=
59 id=29822 iplen=44
seq=3687542010 win=1024 <mss 1460>
SENT (0.0379s) TCP 210.120.38.29:59289 > 10.129.2.28:80 S t
tl=37 id=29822 iplen=44
seq=3687542010 win=1024 <mss 1460>
SENT (0.0379s) TCP 191.6.64.171:59289 > 10.129.2.28:80 S tt
l=38 id=29822 iplen=44
seq=3687542010 win=1024 <mss 1460>
SENT (0.0379s) TCP 184.178.194.209:59289 > 10.129.2.28:80 S
ttl=39 id=29822 iplen=44
seq=3687542010 win=1024 <mss 1460>
SENT (0.0379s) TCP 43.21.121.33:59289 > 10.129.2.28:80 S tt
l=55 id=29822 iplen=44
seq=3687542010 win=1024 <mss 1460>
RCVD (0.1370s) TCP 10.129.2.28:80 > 10.10.14.2:59289 SA ttl
=64 id=0 iplen=44
seq=4056111701 win=64240 <mss 1460>
Nmap scan report for 10.129.2.28
Host is up (0.099s latency).
```

```
PORT   STATE SERVICE
80/tcp open  http
MAC Address: DE:AD:00:00:BE:EF (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 0.15 seconds
```

Scanning Options	Description
`10.129.2.28`	Scans the specified target.
`-p 80`	Scans only the specified ports.
`-sS`	Performs SYN scan on specified ports.
`-Pn`	Disables ICMP Echo requests.
`-n`	Disables DNS resolution.
`--disable-arp-ping`	Disables ARP ping.
`--packet-trace`	Shows all packets sent and received.
`-D RND:5`	Generates five random IP addresses that indicates the source IP the connection comes from.

The spoofed packets are often filtered out by ISPs and routers, even though they come from the same network range. Therefore, we can also specify our VPS servers' IP addresses and use them in combination with "`IP ID`" manipulation in the IP headers to scan the target.

Another scenario would be that only individual subnets would not have access to the server's specific services. So we can also manually specify the source IP address (`-S`) to test if we get better results with this one. Decoys can be used for SYN, ACK, ICMP scans, and OS detection scans. So let us look at such an example and determine which operating system it is most likely to be.

Testing Firewall Rule

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -n -Pn -p445 -O

Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-22 01:23
CEST
Nmap scan report for 10.129.2.28
```

```
Host is up (0.032s latency).

PORT    STATE    SERVICE
445/tcp filtered microsoft-ds
MAC Address: DE:AD:00:00:BE:EF (Intel Corporate)
Too many fingerprints match this host to give specific OS d
etails
Network Distance: 1 hop

OS detection performed. Please report any incorrect results
at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.14 seconds
```

Scan by Using Different Source IP

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -n -Pn -p 445 -O -S
10.129.2.200 -e tun0

Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-22 01:16
CEST
Nmap scan report for 10.129.2.28
Host is up (0.010s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: DE:AD:00:00:BE:EF (Intel Corporate)
Warning: OSScan results may be unreliable because we could
not find
at least 1 open and 1 closed port
Aggressive OS guesses: Linux 2.6.32 (96%), Linux 3.2 - 4.9
(96%),
Linux 2.6.32 - 3.10 (96%), Linux 3.4 - 3.10 (95%), Linux 3.
1 (95%),
Linux 3.2 (95%), AXIS 210A or 211 Network Camera (Linux 2.
6.17) (94%),
Synology DiskStation Manager 5.2-5644 (94%), Linux 2.6.32 -
2.6.35 (94%),
Linux 2.6.32 - 3.5 (94%)
```

```
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

OS detection performed. Please report any incorrect results
at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.11 seconds
```

Scanning Options	Description
`10.129.2.28`	Scans the specified target.
`-n`	Disables DNS resolution.
`-Pn`	Disables ICMP Echo requests.
`-p 445`	Scans only the specified ports.
`-O`	Performs operation system detection scan.
`-S`	Scans the target by using different source IP address.
`10.129.2.200`	Specifies the source IP address.
`-e tun0`	Sends all requests through the specified interface.

DNS Proxying

By default, `Nmap` performs a reverse DNS resolution unless otherwise specified to find more important information about our target. These DNS queries are also passed in most cases because the given web server is supposed to be found and visited. The DNS queries are made over the `UDP port 53`. The `TCP port 53` was previously only used for the so-called "`Zone transfers`" between the DNS servers or data transfer larger than 512 bytes. More and more, this is changing due to IPv6 and DNSSEC expansions. These changes cause many DNS requests to be made via TCP port 53.

However, `Nmap` still gives us a way to specify DNS servers ourselves (`--dns-server <ns>,<ns>`). This method could be fundamental to us if we are in a demilitarized zone (`DMZ`). The company's DNS servers are usually more trusted than those from the Internet. So, for example, we could use them to interact with the hosts of the internal network. As another example, we can use `TCP port 53` as a source port (`--source-port`) for our scans. If the administrator uses the firewall to control this port and does not filter IDS/IPS properly, our TCP packets will be trusted and passed through.

SYN-Scan of a Filtered Port

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -p50000 -sS -Pn -n -
-disable-arp-ping
--packet-trace

Starting Nmap 7.80 ( https://nmap.org ) at 2020-06-21 22:50
CEST
SENT (0.0417s) TCP 10.10.14.2:33436 > 10.129.2.28:50000 S t
tl=41 id=21939 iplen=44
seq=736533153 win=1024 <mss 1460>
SENT (1.0481s) TCP 10.10.14.2:33437 > 10.129.2.28:50000 S t
tl=46 id=6446 iplen=44
seq=736598688 win=1024 <mss 1460>
Nmap scan report for 10.129.2.28
Host is up.

PORT      STATE    SERVICE
50000/tcp filtered ibm-db2

Nmap done: 1 IP address (1 host up) scanned in 2.06 seconds
```

SYN-Scan From DNS Port

```
pecna@htb[/htb]$ sudo nmap 10.129.2.28 -p50000 -sS -Pn -n -
-disable-arp-ping
--packet-trace --source-port 53

SENT (0.0482s) TCP 10.10.14.2:53 > 10.129.2.28:50000 S ttl=
58 id=27470 iplen=44
seq=4003923435 win=1024 <mss 1460>
RCVD (0.0608s) TCP 10.129.2.28:50000 > 10.10.14.2:53 SA ttl
=64 id=0 iplen=44
seq=540635485 win=64240 <mss 1460>
Nmap scan report for 10.129.2.28
Host is up (0.013s latency).

PORT      STATE SERVICE
```

```
50000/tcp open  ibm-db2
MAC Address: DE:AD:00:00:BE:EF (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 0.08 seconds
```

Scanning Options	Description
`10.129.2.28`	Scans the specified target.
`-p 50000`	Scans only the specified ports.
`-sS`	Performs SYN scan on specified ports.
`-Pn`	Disables ICMP Echo requests.
`-n`	Disables DNS resolution.
`--disable-arp-ping`	Disables ARP ping.
`--packet-trace`	Shows all packets sent and received.
`--source-port 53`	Performs the scans from specified source port.

Now that we have found out that the firewall accepts `TCP port 53`, it is very likely that IDS/IPS filters might also be configured much weaker than others. We can test this by trying to connect to this port by using `Netcat`.

Connect To The Filtered Port

```
pecna@htb[/htb]$ ncat -nv --source-port 53 10.129.2.28 5000
0

Ncat: Version 7.80 ( https://nmap.org/ncat )
Ncat: Connected to 10.129.2.28:50000.
220 ProFTPd
```